AP CYBERSECURITY | INVESTIGATION LAB - STUDENT

LAB 4

The Midnight Login

Unit 4: Linux and Virtual Machines | 50 to 65 minutes

Your role

You are a security analyst on call. At 9 AM the server's owner reports that the payroll file looks wrong and an old log file is missing. You will investigate a copy of the server's authentication log **inside your Linux virtual machine**, using terminal commands to find out who got in, how, and what they did.

What you will do

- Take a VM snapshot before you start, so you can always roll back
- Use grep, wc, awk, sort, uniq, and pipes to answer questions from a log
- Tell brute force from password spraying using evidence
- Read a Linux permission string and spot a dangerous setting
- Recommend ways to protect log integrity

EXAM LENS

Every lab follows the same four stages: **Learn the concept, Investigate the evidence, Make a security decision, then Answer AP-style questions.** Commands show you what happened. The skill is deciding what the evidence *proves*, what it *does not prove*, and what to do next.

COMMON TRAP

This is a **fictional, controlled** investigation. Never scan, test, or access real school systems, other people's accounts, or any device you do not own or have written permission to use.

Original practice material written in the style of the AP Cybersecurity exam. Not reproduced from College Board.

Mission Briefing

You have a copy of `/var/log/auth.log` from the server `srv` for the morning of Oct 14, and a directory listing of the reports folder. Use the terminal for every number you report, and write the **command** next to each answer.

Evidence files

File	What it is
auth.log	Authentication log, Oct 14 (29 lines): logins, failures, sudo commands
dir_listing.txt	Output of ls -l on /srv/reports from the server

Set up your VM

- Start your Ubuntu or Kali VM. **Take a snapshot** named `before-lab4` (VM menu, Snapshots).
- Copy `auth.log` and `dir_listing.txt` into the VM (shared folder, download link, or copy and paste).
- Open a terminal and move to the folder that holds them:

```
cd ~/lab4
ls -l
pwd
```

These are **copies**. The real server is never touched. If you make a mistake, restore the snapshot.

STAGE 1 Learn

Be able to explain these before you touch the evidence

- ■ I can explain what each command does: grep, wc -l, awk, sort, uniq -c, and the pipe |.
- ■ I can read a log line: timestamp, host, service, event, user, and source address.
- ■ I can tell brute force (one account, many guesses) from password spraying (many accounts).
- ■ I can read an ls -l permission string for owner, group, and others.

STAGE 2 Investigate

Collect facts. Record what you observe, not what you assume.

1. How many lines are in `auth.log`? Write the command and the result.

2. How many failed password attempts are there? Write the command and the result.

3. Run this pipeline. Write the output, then explain what **each part** of the pipeline does.

```
grep "Failed password" auth.log | awk '{print $NF}' | sort | uniq -c | sort -rn
```

4. Two outside addresses produced most failures. For each, decide: **brute force** or **password spraying**? Show the evidence (which accounts, how many, what times).

```
grep 198.51.100.9 auth.log
grep "Failed password for admin" auth.log | grep 203.0.113.8
```

5. Did either attack succeed? Run `grep Accepted auth.log`. Which line is suspicious, and why? Which failure is probably **normal**?

6. Run `grep sudo auth.log`. List what the adversary did as admin and say what **attack phase or goal** each command suggests.

```
grep sudo auth.log
```

7. Read `dir_listing.txt`. What is wrong with the permissions of `payroll.csv`? Which CIA properties are at risk? What **chmod** command would you use and why?

```
-rw-rw-rw- 1 admin finance  18240 Oct 14 02:12 payroll.csv
-rw-r----- 1 admin finance   9120 Oct  1 16:40 budget_q3.xlsx
-rw------- 1 root  root      2048 Aug 15 09:00 notes_private.txt
```

8. The adversary deleted `auth.log.1`. How can the organization still keep evidence like this? Name **two** protections.

9. Why was it smart to investigate inside a **VM with a snapshot**? Give two reasons.

STAGE 3 Make a Security Decision

Turn evidence into a defensible recommendation

What can you confirm? (at least three facts, with the command that shows each)

What is uncertain? (at least two things the log does not tell you)

What do you recommend? Give one immediate action, one account or access fix, and one logging fix.

STAGE 4 AP-Style Questions

Transfer what you learned to a new situation

1. An analyst types the following command.

```
$ grep "Failed password" auth.log | wc -l
19
```

What does the number 19 represent?

- **A.** The number of lines in auth.log that contain 'Failed password'
- **B.** The number of different users who failed to log in
- **C.** The size of auth.log in kilobytes
- **D.** The line number of the first failed login

2. A directory listing shows a file that was changed unexpectedly.

```
-rw-rw-rw-  1  admin  finance  18240  Oct 14 02:12  payroll.csv
```

Which statement best describes the security risk?

- **A.** Only the owner can read the file
- **B.** Execute permission was removed from the owner
- **C.** Members of the group cannot read the file
- **D.** Every user on the system can read and change the file

3. After an intrusion, the adversary deleted a log file that showed what they did.

Which action would best make sure this kind of evidence is preserved in the future?

- **A.** Allow all administrators to edit logs
- **B.** Delete older logs weekly to save space
- **C.** Send logs in real time to a separate, protected log server
- **D.** Turn off logging for administrator accounts

4. An analyst reviews a sudo entry.

```
Oct 14 02:14:02 srv sudo: admin : COMMAND=/bin/rm /var/log/auth.log.1
```

Which attack phase does this entry best represent?

A. Reconnaissance
B. Evading detection
C. Persistence
D. Initial access

Evidence Printout

Printed copies of the evidence files, for students without a terminal. The files themselves are in the evidence folder.

auth.log

```
Oct 14 01:32:27 srv sshd[2014]: Failed password for root from 198.51.100.9
Oct 14 01:32:28 srv sshd[2016]: Failed password for sam from 198.51.100.9
Oct 14 01:32:29 srv sshd[2018]: Failed password for lee from 198.51.100.9
Oct 14 01:32:30 srv sshd[2020]: Failed password for nina from 198.51.100.9
Oct 14 01:32:31 srv sshd[2022]: Failed password for jordan from 198.51.100.9
Oct 14 01:32:32 srv sshd[2024]: Failed password for guest from 198.51.100.9
Oct 14 02:10:05 srv sshd[2026]: Failed password for admin from 203.0.113.8
Oct 14 02:10:07 srv sshd[2028]: Failed password for admin from 203.0.113.8
Oct 14 02:10:09 srv sshd[2030]: Failed password for admin from 203.0.113.8
Oct 14 02:10:11 srv sshd[2032]: Failed password for admin from 203.0.113.8
Oct 14 02:10:13 srv sshd[2034]: Failed password for admin from 203.0.113.8
Oct 14 02:10:15 srv sshd[2036]: Failed password for admin from 203.0.113.8
Oct 14 02:10:17 srv sshd[2038]: Failed password for admin from 203.0.113.8
Oct 14 02:10:19 srv sshd[2040]: Failed password for admin from 203.0.113.8
Oct 14 02:10:21 srv sshd[2042]: Failed password for admin from 203.0.113.8
Oct 14 02:10:23 srv sshd[2044]: Failed password for admin from 203.0.113.8
Oct 14 02:10:25 srv sshd[2046]: Failed password for admin from 203.0.113.8
Oct 14 02:10:27 srv sshd[2048]: Failed password for admin from 203.0.113.8
Oct 14 02:10:31 srv sshd[2050]: Accepted password for admin from 203.0.113.8
Oct 14 02:11:20 srv sudo: admin : COMMAND=/usr/bin/cat /etc/shadow
Oct 14 02:12:45 srv sudo: admin : COMMAND=/usr/bin/vi /srv/reports/payroll.csv
Oct 14 02:14:02 srv sudo: admin : COMMAND=/bin/rm /var/log/auth.log.1
Oct 14 02:15:10 srv sshd[2052]: session closed for user admin
Oct 14 07:51:10 srv sshd[2002]: Accepted password for sam from 10.0.0.14
Oct 14 08:01:58 srv sshd[2012]: Failed password for lee from 10.0.0.22
Oct 14 08:02:33 srv sshd[2004]: Accepted password for lee from 10.0.0.22
Oct 14 08:15:05 srv sshd[2006]: Accepted password for nina from 10.0.0.31
Oct 14 09:01:47 srv sshd[2008]: Accepted password for admin from 10.0.0.5
Oct 14 09:40:12 srv sshd[2010]: Accepted password for jordan from 10.0.0.40
```

dir_listing.txt

```
$ ls -l /srv/reports
-rw-rw-rw- 1 admin finance  18240 Oct 14 02:12 payroll.csv
-rw-r----- 1 admin finance   9120 Oct  1 16:40 budget_q3.xlsx
-rwxr-xr-x 1 admin admin      512 Sep 20 11:05 backup.sh
-rw------- 1 root  root      2048 Aug 15 09:00 notes_private.txt
```

KEY IDEA

Before you turn this in: every answer should name the evidence it comes from (a file name, a line, a time, or a command result). If you are not sure something is proven, write 'not confirmed' and say what evidence would confirm it.